

NORMAS DE ATENDIMENTO — TI SUPORTE

Política de Segurança da Informação e Controle de Acesso

Versão 4.0 | Aprovado em: 01/02/2025 | Revisão: 01/02/2026

1. Objetivo e Base Legal

Estabelecer diretrizes de segurança da informação para o atendimento de suporte de TI, em conformidade com a LGPD (Lei 13.709/2018), ISO 27001:2022 e políticas corporativas internas. Todos os analistas de suporte devem conhecer e cumprir estas normas integralmente.

2. Gestão de Identidade e Acesso (IAM)

2.1 Provisionamento de Acesso

Todo novo acesso deve ser solicitado formalmente pelo gestor direto via sistema ITSM. O princípio do menor privilégio (PoLP) deve ser aplicado em todos os casos: o usuário recebe apenas os acessos estritamente necessários para sua função.

Tipo de Acesso	Solicitante	Aprovador	SLA Provisão	Revisão
Conta AD / E-mail	RH (via sistema)	TI N1	4 horas	Anual
VPN corporativa	Gestor direto	TI N2	1 dia útil	Semestral
Acesso admin local	Gestor + CISO	TI N2 + Segurança	2 dias úteis	Trimestral
Acesso a servidor/BD	Gestor + CTO	TI N3 + CISO	3 dias úteis	Trimestral
Acesso privilegiado (PAM)	Diretor + CISO	CISO + CEO	5 dias úteis	Mensal

2.2 Revogação e Desligamento

Em caso de desligamento, todos os acessos devem ser revogados em até 2 horas após confirmação pelo RH. O processo inclui: bloqueio de conta AD, revogação de VPN, remoção de grupos de e-mail, devolução de equipamentos e revogação de tokens MFA. O não cumprimento deste prazo é considerado incidente de segurança.

2.3 Política de Senhas

- Comprimento mínimo: 12 caracteres (letras maiúsculas, minúsculas, números e símbolos)
- Troca obrigatória: a cada 90 dias para usuários comuns, 30 dias para contas privilegiadas
- Histórico: as últimas 12 senhas não podem ser reutilizadas
- Bloqueio após 5 tentativas inválidas (desbloqueio somente via Service Desk com verificação)
- Senhas padrão de fabricante NUNCA devem ser mantidas em produção
- MFA obrigatório para VPN, e-mail externo, sistemas críticos e acessos privilegiados

3. Manuseio de Dados durante o Atendimento

3.1 Dados Pessoais e Sensíveis (LGPD)

Analistas de suporte podem ter acesso a dados pessoais durante atendimentos remotos. É terminantemente proibido: copiar, fotografar, capturar ou compartilhar dados pessoais de usuários. Sessões de acesso remoto devem ser realizadas com o consentimento e presença do usuário. Logs de acesso remoto são mantidos por 1 ano para fins de auditoria (LGPD Art. 37).

3.2 Compartilhamento de Credenciais

É estritamente proibido compartilhar credenciais entre analistas. Contas de serviço compartilhadas devem ser gerenciadas via cofre de senhas (PAM). Contas genéricas são proibidas para ações administrativas rastreáveis.

4. Dispositivos e Endpoints

4.1 Equipamentos Corporativos

- Todo equipamento corporativo deve ter antivírus/EDR ativo e atualizado (máx. 24h de delay)
- Criptografia de disco obrigatória (BitLocker para Windows, FileVault para macOS)
- Patch de segurança: críticos em 48h, altos em 7 dias, médios em 30 dias
- USB e dispositivos externos: bloqueados por padrão; liberação via solicitação formal
- Equipamentos não devem ser emprestados a terceiros ou familiares
- Perda ou roubo de dispositivo: comunicar ao Service Desk em até 1 hora

5. Resposta a Incidentes de Segurança

Todo analista que identificar ou suspeitar de incidente de segurança (malware, acesso não autorizado, vazamento de dados, phishing bem-sucedido) deve acionar IMEDIATAMENTE o time de Segurança da Informação via canal exclusivo e NÃO deve tentar resolver por conta própria. O isolamento da máquina afetada deve ser feito antes de qualquer ação corretiva. Incidentes com dados pessoais devem ser reportados ao DPO em até 72 horas (LGPD Art. 48).